OWL-DNS-Synergy v3.0.0

Comprehensive Security Audit & Architecture Critique

Component	CRITICAL	HIGH	MEDIUM	LOW	Total
SmartChannelRouter v3	4	5	1	0	10
LLM-DNS-Proxy	4	3	1	0	8
OWL-AGENT v4.2 Core	2	5	1	0	8
AutoClaw-AutoLogin	5	3	1	0	9
TOTAL	**15**	**16**	**4**	**0**	**35**

Total findings: 35 | CRITICAL: 15 | HIGH: 16 | MEDIUM: 4 | LOW: 0
Fixes applied in this audit: 16 | Remaining: 19

SmartChannelRouter v3

[CRITICAL] F-1: CONNECT_CHAIN missing from fallback_order FIXED

Channel.CONNECT_CHAIN is defined in channel_map but excluded from the fallback chain. If HTTP_PROXY fails, CONNECT_CHAIN is never attempted during failover. Only force_channel=CONNECT_CHAIN triggers it, and if it fails, no retry occurs.

> **Fix:** Add Channel.CONNECT_CHAIN between MITM_STEALTH and HTTP_DIRECT in fallback_order (line 1083). FIXED in this audit.

[CRITICAL] F-2: DNS tunnel _try_dns_tunnel always reports success (no-op) FIXED

Creates a UDP socket and immediately closes it without sending any DNS query. DNS_TUNNEL always returns success=True with sentinel string "[DNS tunnel available for domain]", preventing failover to subsequent channels (MITM_STEALTH, CONNECT_CHAIN, HTTP_DIRECT never tried).

> **Fix:** Replaced with actual DNS health-check query that sends a minimal DNS packet and waits for response. Returns success=False on timeout/connection-refused. FIXED in this audit.

[CRITICAL] F-3: No circuit breaker implementation

ChannelState enum (PREFERRED/FALLBACK/HYBRID_RETRY) and self._states are initialized but never used. The circuitbreaker package is declared in pyproject.toml but never imported in router_v3.py. Persistently failing channels are retried every request with no backoff.

> **Fix:** Import circuitbreaker package and wrap each channel method. Track half-open state in Prometheus gauge.

[CRITICAL] F-4: DomainPreference EMA system is entirely dead

DomainPreference dataclass has successes/failures dicts that are never incremented, preferred_channel never updated, last_updated never modified. No EMA decay logic exists. The entire domain preference system is a ghost of intended functionality.

> **Fix:** Implement update() method on DomainPreference that increments successes/failures and recomputes preferred_channel using EMA. Call from channel success/failure handlers.

[HIGH] F-5: HTTP proxy reports success for all status codes FIXED

_try_http_proxy returns success=True even for 404/500/502 responses. Only 401/403/429 are reported to key_rotator. This prevents failover to next channel when upstream returns an error.

> **Fix:** Changed to: is_success = 200 <= resp.status_code < 300. Only cache on 2xx. FIXED in this audit.

[HIGH] F-6: New httpx.AsyncClient per request (no connection pooling)

Each HTTP call creates httpx.AsyncClient() as context manager, creating new TCP connections and TLS handshakes every time. 5+ call sites do this. For sustained traffic this is 5-10x slower than a shared client.

> **Fix:** Create shared httpx.AsyncClient in __init__ and reuse across all methods.

[HIGH] F-7: DNSFloodProtector: global token consumed before per-client check FIXED

If global bucket allows (token consumed) but per-client rejects, the token is permanently lost. Under sustained attack, global bucket drains faster than intended.

> **Fix:** Reordered: per-client check FIRST, then global token consumption. FIXED in this audit.

[HIGH] F-8: AutoClawAdapter silently swallows all exceptions FIXED

get_next_token() catches Exception with bare "pass" - no logging, no metrics, no re-raise. Impossible to diagnose why autoclaw returns None.

> **Fix:** Added logger.warning() in exception handler. FIXED in this audit.

[HIGH] F-9: AutoClawAdapter mislabels channel as "http_proxy" FIXED

chat_completion() returns ChannelResult("http_proxy", ...) instead of "autoclaw". Corrupts Prometheus metrics - autoclaw requests indistinguishable from proxy pool.

> **Fix:** Changed to "autoclaw". FIXED in this audit.

[MEDIUM] F-10: Unbounded cache with no eviction

self._cache is a plain Dict with no size limit or LRU eviction. Long-running processes will experience unbounded memory growth. Expired entries only removed on access (lazy deletion).

> **Fix:** Add max_size parameter and FIFO eviction in _cache_set().

LLM-DNS-Proxy

[CRITICAL] D-1: Base36 "z" separator collision causes data corruption FIXED
bytes_to_base36() uses "z" as separator between length prefix and data. But "z" is a valid base36 digit (representing 35). When len(data) has a base36 encoding containing "z", base36_to_bytes() splits at the wrong position, causing unrecoverable decode failures.

Fix: Changed separator from "z" to "_" (non-base36 character). FIXED in this audit.

[CRITICAL] D-2: Session ID only 1000 values - birthday collision FIXED
Session ID space is only 1000 (000-999). With 38+ concurrent sessions there is >50% probability of collision. Colliding sessions mix each other's data - server merges chunks from different clients.

Fix: Changed to 8-hex-digit session ID (4 billion values). FIXED in this audit.

[CRITICAL] D-3: No replay attack protection in Fernet decrypt FIXED
Fernet tokens embed a timestamp but decrypt() is called without ttl parameter. Captured encrypted DNS queries can be replayed indefinitely.

Fix: Added ttl=300 (5 min) to all decrypt() calls. FIXED in this audit.

[CRITICAL] D-4: Silent key mismatch when LLM_PROXY_KEY unset FIXED
If LLM_PROXY_KEY env var is unset, each side independently generates a different random key. Communication silently fails with no clear error.

Fix: Now raises ValueError with clear message instead of silently generating key. FIXED in this audit.

[HIGH] D-5: No UDP retry on chunk send
Message chunks sent via UDP with no retry. If a single packet is lost, the server never receives that chunk and the message is incomplete forever.

Fix: Implement ACK-based retry: if response != "OK", resend up to N times.

[HIGH] D-6: total_chunks overwrite without validation (DoS) FIXED
An attacker can send chunk 0 with total=2, then chunk 1 with total=999999, and the server waits for 999999 chunks (DoS).

Fix: Added mismatch check: reject if total_chunks differs from already-set value. FIXED in this audit.

[HIGH] D-7: Chunk count completion check is insufficient FIXED
Only checks len(pending) == total_chunks, not that indices are 0..N-1. Sending chunk 0 twice with total=2 passes but uses chunk 0 twice.

Fix: Changed to set comparison: set(keys()) == set(range(total)). FIXED in this audit.

[MEDIUM] D-8: No decompression size limit (zip bomb) FIXED
zlib.decompress() called without wbits size limiting. Malicious sender could craft small encrypted payload that decompresses to gigabytes.

Fix: Added bufsize=10MB limit. FIXED in this audit.

OWL-AGENT v4.2 Core

[CRITICAL] O-1: RequestDeduplicator deadlock - await Future while holding Lock FIXED

Second caller acquires _lock, finds in-flight Future, then awaits the Future while still holding the lock. First caller cannot complete (cannot reach finally block to release key) because lock is held. Classic asyncio deadlock.

Fix: Restructured: release lock before awaiting in-flight Future. FIXED in this audit.

[CRITICAL] O-2: TokenBucket recursive acquire can stack overflow FIXED

If rate is low or tokens is high, acquire() recurses indefinitely. Each recursion creates a new stack frame. Under sustained load, this will overflow the Python call stack.

Fix: Replaced recursion with while True loop. FIXED in this audit.

[HIGH] O-3: HTTPCache disk write non-atomic; binary content corruption

Content decoded with errors="replace" silently corrupts non-UTF-8 binary content. Non-atomic disk write - crash mid-write leaves truncated JSON file.

Fix: Write to temp file then os.replace() (atomic rename). Use base64 for content.

[HIGH] O-4: HTTPCache not actually LRU - is FIFO/TTL

Docstring says "LRU + disk" but _memory is a plain Dict. Eviction sorts by timestamp and removes oldest - this is FIFO, not LRU. Frequently accessed entries never promoted.

Fix: Use OrderedDict with move-to-end on access.

[HIGH] O-5: QualityScorer - no thread safety; alpha not validated

_scores and _history modified without any lock. decay_factor not bounded to [0,1]: value 1.0 = frozen score, >1.0 = divergence to infinity, <0 = oscillation.

Fix: Add asyncio.Lock, validate 0 < decay < 1.

[HIGH] O-6: CircuitBreaker imported but never used as decorator

The circuitbreaker package is instantiated but never applied to any function. Prometheus gauge only sets 0/1 (closed/open), never 2 (half-open). Cascading failure risk under systemic outage.

Fix: Implement custom 3-state CircuitBreaker with explicit half-open tracking.

[HIGH] O-7: curl_cffi imported but never used - no Chrome impersonation

CURL_CFFI_AVAILABLE flag set but no code uses CurlAsyncSession. All requests use Python default TLS with distinctive JA3 fingerprint easily detected by anti-bot services. Chrome 110 is outdated (current ~131).

Fix: Implement CurlCffiClient wrapper with impersonate="chrome131".

[MEDIUM] O-8: AdaptiveRateLimiter multiplicative increase causes starvation

Decrease: rate * 0.5, Increase: rate * 1.1. Takes 11 successes to recover from one 429. min_rate=0.1 req/s may be too slow. No burst handling.

Fix: Consider additive increase (+0.1) for faster recovery. Add token bucket per-domain.

AutoClaw-AutoLogin

[CRITICAL] A-1: Hardcoded APP_KEY in source code (config.py:7)

APP_KEY = "38d2391985e2369a5fb8227d8e6cd5e5" is the signing secret. Anyone with repo access can forge valid X-Auth-Sign headers and impersonate any AutoClaw client.

Fix: Move to environment variable: APP_KEY = os.environ.get("AUTOCLAW_APP_KEY").

[CRITICAL] A-2: TLS verification disabled globally (verify=False)

urllib3.disable_warnings() + verify=False on every requests call. All outbound requests (OAuth token exchange, refresh, wallet, chat) vulnerable to MITM attacks.

Fix: Remove verify=False. Specify CA bundle if upstream uses private CA.

[CRITICAL] A-3: Tokens stored in plaintext JSON (tokens.json)

tokens.json contains raw access_token and refresh_token. No encryption, no file permission restrictions (not even chmod 600). Tokens persist indefinitely.

Fix: Encrypt at rest with Fernet. Set os.chmod(TOKENS_FILE, 0o600) after write.

[CRITICAL] A-4: Google passwords in plaintext on disk (accounts.txt)

accounts.txt stores email:password in cleartext. These are Google account passwords - compromise = full account takeover.

Fix: Use OS keyring or encrypted storage. Set chmod 600 on file.

[CRITICAL] A-5: Single Flask dev server in production

Flask built-in server is not production-ready. No worker management, no graceful shutdown, no auto-restart. Single unhandled exception crashes entire server.

Fix: Use gunicorn or waitress as WSGI server.

[HIGH] A-6: Dashboard on 0.0.0.0 with no authentication FIXED

Proxy server and dashboard exposed on all interfaces with zero auth. Anyone on LAN can use chat completions, view accounts, delete accounts.

Fix: Changed default to 127.0.0.1. Add API key middleware. FIXED in this audit.

[HIGH] A-7: No rate limiting on /v1/chat/completions

Any client can send unlimited requests, burning through all accounts credits. No per-client, per-account, or global rate limit.

Fix: Add flask-limiter: per-IP, per-account, and global RPM limits.

[HIGH] A-8: No model validation - silent fallback to expensive model

Unknown model name silently falls back to DEFAULT_MODEL (openrouter_glm-5.2 - the most expensive). Typo "glm5.2" routes to premium without warning.

Fix: Return 400 for unknown models. Log warning on fallback.

[MEDIUM] A-9: No CORS policy - any website can call the API

No CORS configuration. Any website user visits can make XHR to localhost:31000.

Fix: Add flask-cors restricted to localhost origins.

Applied Fixes Summary

File	Issue	Fix Applied
chunking.py (x2)	Base36 "z" separator collision	Changed separator from "z" to "_" (non-base36 char)
chunking.py (x2)	Session ID birthday collision (1000 values)	Changed to 8-hex-digit (4B values)
chunking.py (x2)	total_chunks overwrite DoS	Added mismatch validation check
chunking.py (x2)	Chunk completion check insufficient	Changed to set comparison of indices
crypto.py	No replay attack protection	Added ttl=300 to all decrypt() calls
crypto.py	Silent key mismatch on missing LLM_PROXY_KEY	Raises ValueError with clear message
crypto.py	No zip bomb protection	Added bufsize=10MB limit to decompress
core.py	RequestDeduplicator deadlock	Release lock before awaiting in-flight Future
core.py	TokenBucket recursive stack overflow	Replaced recursion with while True loop
core.py	Base36 separator (mirrored)	Same fix as chunking.py
router_v3.py	DNS tunnel no-op always succeeds	Replaced with actual DNS health-check query
router_v3.py	CONNECT_CHAIN missing from fallback	Added to fallback_order between MITM and HTTP_DIRECT
router_v3.py	HTTP proxy success on all status codes	Changed to is_success = 2xx only, cache only on 2xx
router_v3.py	DNSFloodProtector token leak	Reordered: per-client check before global token consume
router_v3.py	AutoClawAdapter silent exception	Added logger.warning() in exception handler
router_v3.py	AutoClawAdapter channel mislabel	Changed from "http_proxy" to "autoclaw"
config.py (autoclaw)	Dashboard on 0.0.0.0 with no auth	Changed default to 127.0.0.1

Remaining Critical/High Priority Items

Priority	Item	Recommended Action
CRITICAL	Implement 3-state CircuitBreaker in router_v3.py	Import circuitbreaker package, wrap channel methods, track half-open stat
CRITICAL	Implement DomainPreference EMA update logic	Add update() method, call from channel success/failure handlers
CRITICAL	Move AutoClaw APP_KEY to env var	config.py: APP_KEY = os.environ.get("AUTOCLAW_APP_KEY")
CRITICAL	Enable TLS verification in AutoClaw	Remove verify=False, specify CA bundle if needed
CRITICAL	Encrypt AutoClaw tokens at rest	Use Fernet encryption for tokens.json, chmod 600
CRITICAL	Replace Flask dev server with gunicorn	Add gunicorn to requirements.txt, update startup
HIGH	Share httpx.AsyncClient across router lifetime	Create in __init__, reuse in all methods
HIGH	Add UDP retry for DNS chunk sends	ACK-based retry: resend up to 3x on no response
HIGH	Implement actual curl_cffi Chrome impersonation	CurlCffiClient with impersonate="chrome131"
HIGH	Add rate limiting to AutoClaw proxy	flask-limiter: per-IP, per-account, global RPM
HIGH	Fix HTTPCache binary corruption + atomic writes	base64 for content, temp file + os.replace()
HIGH	Add model validation with 400 on unknown models	Reject unknown models instead of silent fallback